

**INTERNATIONAL CYBERSECURITY AND DIGITAL
FORENSICS ACADEMY (ICDFA)**

**GRC102: INFORMATION SECURITY GOVERNANCE
ASSIGNMENT 1**

Principles of Information Security Governance

RABIATU UMAR AHMAD

C11/26/CGRCE/17569

COHORT 11

10th September, 2026

Part 1 - Governance Structure Analysis

Tasks:

1. Weaknesses identified in TechCorp's Current Information Security include the following:
 - a. Security decisions are carried out within the IT department: The first weakness is that information security is managed within IT and most decisions are made by the IT Director.

Governance issue: There is no complete separation between operational IT responsibilities and independent security governance. The IT Director may have other priorities which may clash with security requirements.

Potential business impact: There may be important security risks that requires attention but can be overlooked because of operational priorities. This can increase the likelihood of data breaches, service interruptions, regulatory penalties and reputational damage.

Impact on international expansion: International operations will expose TechCorp to different regulatory, contractual and privacy requirements. A single IT-based decision-making structure may not provide all these requirements.

- b. There is no formal security governance committee: TechCorp currently has no formal security committee or governance body.

Governance issue: There is no structured system where business, risk, legal, compliance, IT and security leaders can collectively review cybersecurity risks and make decisions.

Potential business impact: Security decisions may become fragmented and reactive. Major risks may not be reported to senior management in time for actions to take place

Impact on international expansion: International expansion increases the number of stakeholders and regulatory requirements. A governance committee would provide a coordinated approach to security and compliance across different places worldwide.

- c. Board involvement is not adequate: The Board receives only a brief security update once a year.

Governance issue: The Board is not receiving enough information on cybersecurity risk. Effective governance requires senior involvement to understand important information-security risks and ensure that management is addressing them.

Potential business impact: The Board may not know about important vulnerabilities, unresolved security risks or resource requirements until a major incident occurs.

Impact on international expansion: As TechCorp expands, cybersecurity risks will become more important. No proper involvement of Board could result in poor investment decisions and insufficient attention to international compliance obligations.

- d. Security policies are outdated and not followed consistently: TechCorp has security policies, but they are outdated and inconsistently followed.

Governance Issue: Policies are only useful when they are current, communicated, implemented and monitored. In TechCorp it shows a gap between policy and actual practice.

Potential business impact: Employees may follow different security practices, creating inconsistent controls. This could lead to unauthorized access, data loss, weak password practices or failure to respond correctly to incidents.

Impact on international expansion: Different countries and clients may require specific security and privacy controls. Outdated policies may prevent TechCorp from meeting contractual or regulatory expectations.

- e. Incident management is reactive: Security incidents are handled reactively without a formal governance or escalation process.

Governance Issue: The organization lacks defined responsibilities and escalation thresholds for cybersecurity incidents.

Potential business impact: When there is a delayed response, it could increase the financial and operational impact of an incident. Management may also fail to notify appropriate stakeholders or regulators within required timeframes.

Impact on international expansion: International operations can create different incident-reporting requirements. A weak incident governance process could result in delayed reporting and additional regulatory consequences.

- 2. a. Board of Directors /Audit Committee: The Board should provide strategic oversight rather than manage day-to-day security operations.

Their responsibilities should include: Approving the organization's overall risk appetite, receiving regular cybersecurity reports, reviewing major security risks.

b. Executive Security Committee: Their responsibilities should include:

- * reviewing the enterprise security risk register.
- * reviewing significant incidents.
- * resolving cross-functional security issues.
- * monitoring regulatory requirements.
- * recommending major decisions to the Board.

c. Information Officer: Their responsibilities should include the following:

- * developing the information security strategy.
- * establish security policy and standards.
- * coordinating vulnerability management.
- * reporting significant risks to executive management and the Board.
- * monitor compliance and developing security awareness program.

d. . IT Director: The IT Director should remain responsible for technology operations but should not be the sole decision-maker for security.

Responsibilities would include:

- * implementing approved security controls;
- * maintaining secure infrastructure;
- * ensuring patching and system maintenance;
- * supporting business continuity
- * providing resources for security remediation.

- Decision-making and escalation process: TechCorp should introduce a formal escalation process. Low-level operational issues can be managed by security and IT teams. Medium risks should be reported to the information security officer and relevant business owners. High and critical risks should be escalated to the Executive Security Committee and where necessary the Board should be involved.
- Board Involvement and Reporting: Instead of receiving one short report yearly, the Board should receive cybersecurity reports quarterly, with immediate escalation for critical incidents.

3. The information Security officer is responsible for the security program, business owners are accountable for risks affecting their areas, and the Board provides oversight. Security should support TechCorp's business objectives rather than operate independently. This is especially important because the company plans to expand internationally. The Board and security governance committee provide oversight of management. This reduces the risk that security decisions will be controlled solely by the operational IT function. Security governance should not be static. Policies, controls, risks and performance should be reviewed regularly and improved based on incidents, audits, regulatory changes and changes in the business environment.

Part 2 - Framework Comparison and Selection

4.

Criteria	COBIT	ISO/IEC/27001
Scope and primary focus	Broad governance and management of enterprise information and technology.	Information security management and protection of information assets.
Structure and major components	Governance and management objectives, principles, design factors and implementation guidance.	It include requirement for leadership, planning, support, operation, performance evaluation and continual improvement.
Governance approach	Strong emphasis on governance, accountability, stakeholder needs, value and alignment between business and technology	Governance is primarily achieved through an ISMS, risk management, leadership commitment and continual improvement.
Certification	COBIT itself is not generally an organizational certification standard equivalent to ISO/IEC 27001 certification	Organizations can undergo independent conformity assessment/certification against ISO/IEC 27001
Risk management	Integrates information and technology risk with enterprise governance and management.	Requires a systematic risk assessment and treatment process within the ISMS.
Control selection	Provides governance and management objectives and allows organizations to design appropriate practices	Uses risk-based control selection, supported by Annex A controls and the organization's Statement of Applicability
Strengths and limitations	Strong for enterprise IT	Strong for information

	governance, accountability	security management
Regulatory alignment	Can help organize governance and control activities that support regulatory compliance.	Can provide a structured security management system that supports regulatory and contractual requirements.
Resource requirements	Requires governance expertise, process ownership, assessment and implementation resources	Requires risk assessment, documentation, control implementation, internal audits, management review and potentially certification costs

5. I would recommend a combination of ISO/IEC 27001 and COBIT framework, with ISO/IEC 27001 serving as the primary information-security management framework and COBIT supporting enterprise governance and management of information and technology.

MedSecure handles sensitive patient information and operates across three states. Its primary requirement is therefore to establish a consistent and risk-based information-security management system.

ISO/IEC 27001 is appropriate because it provides a structured ISMS that can be adapted to an organization's size and risk environment. It also promotes confidentiality, integrity and availability and supports continual improvement.

COBIT should complement because COBIT can strengthen the governance side of the program by connecting security and technology activities with business objectives, stakeholder needs, performance and accountability. This is important because MedSecure is a relatively large organization with approximately 2,000 employees. It needs more than technical controls; it also needs effective governance over information and technology.

6. High-level implementation roadmap for the recommendation

- Phase 1: Initiation and governance

Define scope and also identify the risk

*Critical success factor: strong executive and Board support.

*Likely challenge: competing priorities.

*Mitigation: Security objectives to patient safety, regulatory compliance and business objectives.

- Phase 2: Risk and gap assessment

Perform an enterprise information-security risk assessment.

*Critical success factor: Identify important information assets and risks.

- Phase 3: Framework and control design
Develop the ISO/IEC 27001 ISMS and select appropriate controls. Define COBIT governance objectives.
- Phase 4: Implementation
- Phase 5: Testing and internal audit.
- Phase 6: Certification and continual improvement.

Part 3 - Case Study Analysis: Equifax Data Breach

7. Governance Failures in the Equifax Breach include the following
 - a. Failure to enforce vulnerability-management policies
Equifax was notified of the Apache Struts vulnerability in March 2017, but the affected system was not successfully patched.
Governance issue: The organization had a patching policy but did not follow the policy as required.
Contribution to the breach: The vulnerability provided attackers with an opportunity to exploit the vulnerability.
Principle not adequately applied: Accountability and effective control monitoring.
 - b. Weak asset management: An organization cannot effectively protect systems if it does not have a reliable understanding of how important its asset holds.
Governance issue: Inadequate IT asset inventory and ownership.

Contribution to the breach: If a vulnerable system is not properly identified, it may not receive the required security updates.

Principle not adequately applied: Risk identification and accountability.
 - c. Inadequate network segmentation: Among the failures identified is poor network segmentation.
Governance issue: Security unit did not properly restrict the movement of an attacker after initial attempt.

Contribution to the breach: Once attackers gained access to the environment, insufficient segmentation increased their ability to reach sensitive systems and databases.

Principle not adequately applied: Defence in depth and risk-based security architecture.

- d. Expired SSL certificate and inadequate monitoring:
The expired SSL certificate shows another governance weakness.

Governance issue: There was inadequate monitoring, because with proper monitoring the expired SSL Certificate would have been renewed.

Contribution to the breach: The certificate issue contributed to weaknesses in monitoring and the ability to inspect network traffic effectively.

Principle not adequately applied: Continuous monitoring and control assurance.

- e. Lack of Board oversight

There is an inadequate Board oversight.

Governance issue: Cybersecurity risk was not sufficiently channeled into senior-level oversight.

Contribution to the breach: Without effective oversight, major security weaknesses could remain unresolved.

Principle not adequately applied: Board accountability and strategic oversight.

- 8. Being CISO, I would have focused on creating a governance system in which critical security requirements were assigned, monitored and independently verified.
 - i. Establish a Cybersecurity Governance Committee: The committee would review critical risks, updates and renewing, security incidents and major technology changes.
 - ii. Establish clear accountability: Whenever there is an important asset, it should have a business owner and technical owner.
 - iii. Establish formal risk management: Establish an enterprise with security risk register is of utmost importance.
 - iv. Board reporting: The board should be receiving reports atleast quarterly.
 - v. Improve security monitoring: Security logs should be centrally collected and monitored. Alerts involving sensitive systems should be investigated promptly.
 - vi. Network segmentation: it is very important to segment the network to prevent unauthorized access to sensitive information.

- vii. Establish vulnerability-management governance: Automated patch deployment where appropriate.
9. The Equifax case shows that cybersecurity must be treated as an enterprise governance issue. The wider governance lessons arising from the incident include:
- Regulatory expectations: Regulators expect Equifax to have control over risk and data protection. The money paid for the settlement shows financial consequences due to inadequate data protection.
 - Increased Board involvement: Boards should not rely on a single report yearly. They need meaningful information that allows them to understand cyber risk in business terms. They need report at least quarterly.
 - Executive accountability: The incident shows that security responsibility should not stop at the CISO or IT department. Senior executives should be accountable for ensuring that the organisation's risk-management system works effectively
 - Lessons from such scenario for organization with such large databases. They should segment their network, patch any vulnerability, provide board reports regularly and monitor security infrastructure.

Part 4 - Governance Principles Application

10. Information Security Governance Principles for GlobalFinance

- i. Security is a business responsibility
Importance: every financial organization depends on the customer's data. Security failures can affect customers, financial performance, regulatory standing and reputation.
Practical application: Business executives should own the risks associated with their operations, while security professionals provide advice, standards and assurance.
Challenge: Different managers may believe security is the responsibility of the central security team.
Response: Include security responsibilities in management objectives and performance measures.
- ii. Risk-based decision-making
Importance: Different risk requires different level of treatment. Resources should focus on the risks that could cause the greatest harm.
Practical application: Use a common enterprise risk methodology and risk-rating system.

Challenge: Different regions may assess similar risks differently.

Response: Use a common risk taxonomy and scoring method while allowing local information to influence the assessment.

iii. Global minimum security standards

Importance: A multinational financial organisation needs a consistent baseline of protection.

Practical application: GlobalFinance should establish mandatory minimum requirements for areas like identity and access management and vulnerability management

Challenge: Local regions may have different technologies and operating environments.

Response: Define the required security outcome globally while allowing regions to select appropriate implementation methods.

iv. Security by design

Importance: Security should be the first priority before systems, products and services are deployed.

Practical application: New technology projects should undergo security check and risk assessment thoroughly before implementation.

Challenge: Business teams may consider security reviews a delay.

Response: Build security reviews into normal project-management processes instead of treating them as separate approval exercises.

v. Compliance must be integrated with risk management

Importance: Financial institutions operate under multiple legal and regulatory requirements.

Practical application: Maintain a regulatory obligations register and follow requirements to controls.

Challenge: Different regions have different Regulatory requirements.

Response: Establish global baseline controls and add local requirements where necessary.

vi. Least privilege and strong identity management

Importance: Unauthorized access to financial information can cause significant financial and reputational damage.

Practical application: Use role-based access, multi-factor authentication, privileged-access management and periodic access reviews.

Challenge: Regional business units may resist centralized access management.

Response: Allow local administration where necessary but enforce global identity standards.

vii. Continuous monitoring and assurance

Importance: Security cannot be guaranteed by a one-time assessment.

Practical application: Use security metrics, vulnerability scanning, audits, control testing and continuous monitoring.

Challenge: Large amount of data and alerts can stressed security teams.

Response: Use risk-based monitoring and prioritize critical systems and threats.

11.

➤ Global consistency and local flexibility

GlobalFinance should establish a global minimum security baseline that applies to all regions.

➤ Security requirements and business agility:

Security should support rather than unnecessarily stop business growth.

➤ Compliance obligations and innovation

Compliance should be considered a baseline rather than the maximum level of security

➤ Centralised oversight and distributed responsibility

The central security function should define policies, standards, minimum controls, risk methodology

12. Governance Mechanism for Maintaining Adherence

i. Measuring adherence: Compliance should be measured using a balanced set of indicators.

ii. Accountability at different levels:

Board: Provides oversight and challenges management.

CEO/Executive Committee: Ensures security supports enterprise objectives and resources are available.

CISO: Owns the global security strategy, standards and assurance program.

Regional Security Leaders: Implement global requirements and manage regional risks.

Business Owners: Own the security risks associated with their business processes and information assets.

Employees: Follow security policies and report suspected incidents.

iii. Exception management: Exceptions should not simply be approved informally

- iv. Conflict resolution: Where a regional business requirement conflicts with a global security requirement, the matter should first be addressed by the regional security function.
- v. Continuous review and improvement: The principles should be formally reviewed at least annually.